

(주)해랑금융 위탁사 개선 방안 보고서

수탁사 (피감사)	(주)해랑금융
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	항공 마일리지 연계 결제 API 중계, 결제 데이터 수신·저장·정산, 카드사 연동 토큰화 처리
점검 기간	2026년 01월 26일 ~ 2026년 02월 13일
작성일	2026년 02월 23일

본 보고서는 (주)해랑금융의 개인정보 보호 관리 수준을 점검한 결과를 바탕으로,
각 취약 사항에 대한 구체적인 개선방안과 이행 계획을 기술한 문서입니다.

목차

1. 개선방안 요약	3
1.1 보안 준수율 분류 기준	3
1.2 조치 기한 분류 기준	3
2. 범주별 개선방안 상세	4
2.1 내부 관리 계획 및 조직	4
2.2 접근 통제 및 권한 관리	5
2.3 접속기록 보관 및 점검	6
2.4 비밀번호 관리	6
2.5 접속 보안 및 네트워크	7
2.6 단말기 보안	7
2.7 개인정보 암호화 및 출력통제	8
2.8 개인정보 생명주기	9
3. 이행 점검 로드맵	11
4. 결론 및 향후 조치 계획	12
4.1 향후 조치 일정	12

1. 개선방안 요약

1.1 보안 준수율 분류 기준

분류	양호(Y)	부분양호(P)	취약(N)
점수	1	0.7	0

총점	100 ~ 90	89 ~ 70	69 ~ 50	49 ~ 0
등급	A	B	C	D

- 각 점검항목을 양호, 부분양호, 취약으로 평가하여 분류한다.
- 총점은 53개의 점검항목 점수의 합산을 100점 만점으로 환산한 값이다.
- 환산 점수에 따라 90점 이상 A등급, 70~89점 B등급, 50~69점 C등급, 49점 이하 D등급으로 산정한다.

1.2 조치 기한 분류 기준

구분	긴급	단기	중기
조치 기한	4주	2개월	6개월

- 지적 사항의 심각도에 따라 조치기한을 3단계로 구분한다.
- 개선방안 이행은 긴급, 단기, 중기 순으로 추진한다.

2. 범주별 개선방안 상세

2.1 내부 관리 계획 및 조직

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
보안서약서 미징구	입사자 5명 중 3명 보안서약서 미징구, 퇴사자 전원 비밀유지서약서 미징구, 외주·파견 인력 3명 보안서약서 미징구 상태에서 정산파일 접근권한 보유	보안서약서 미징구 인원 전부 즉시 징구, 보안서약서 징구 체계 설립, 외주·파견 신규 투입 시 계정 발급 전 서약서 징구 조건 시스템화, HR-계정 시스템 연동으로 서약서 미징구자 계정 발급 차단	정보보호팀장 김채윤 인사팀장 이선호

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
내부관리계획서 공표	핵심 내용(암호화 기준·사고 보고 절차) 구두 질의 시 답변 미흡 사례 다수 확인	전 취급자 열람 확인 체계 수립 (미열람자 개별 이메일 통보), 핵심 내용 퀴즈 기반 이해도 점검 연 1회 의무화, 개정 시 재공지 및 이수 확인 절차 강화	정보보호팀장 김채윤
출력물 관리	최근 1개월 출력물 관리대장 기재 다수 누락, 보안 출력 솔루션 미도입, 점검 당일 프린터 트레이에 결제 이력 포함 출력물 2건 방치, 문서고 잠금장치는 구비되어 있으나 반입·반출 관리대장 기재 누락 건 다수	출력물 관리대장 및 반입·반출 관리대장 기재 의무화 재교육 실시, 보안 출력 솔루션 도입 검토 및 예산 계획, 야간·청소 전 출력물 전량 수납 의무화 지침 배포	정보보호팀장 김채윤 총무팀 박하민

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
침해사고 대응절차	(주)하랑항공 담당자 비상연락망 미등재, API Key 유출 시나리오 전용 대응절차 부재, 모의훈련 미실시, (주)하랑항공 통보 SLA(4시간) 미명시	비상연락망에 (주)하랑항공 담당자 연락처 즉시 등재, API Key 유출·결제 데이터 침해 전용 시나리오 수립, 반기 1회 모의훈련 일정 즉시 수립, (주)하랑항공 통보 SLA(4시간) 명시 및 CPO 결재	정보보호팀장 김채윤

2.2 접근 통제 및 권한 관리

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
차등권한 미적용	역할 기반 접근통제(RBAC) 실제 적용 현황 대조 시 불일치, API 개발팀 5명 중 3명이 운영 결제 DB 직접 접근 권한 보유 - 권한 크리프 상태, 사용자 계정 권한 적절성 검토 미실시	역할 기반 접근통제(RBAC) 문서에 맞게 실제 적용 실시, 개발팀 운영 DB 직접 접근 차단 (방화벽 ACL 및 DB 접근통제 수정), 개발/운영 환경 권한 분리 정책 수립 및 문서화, 사용자 권한 적절성 검토 즉시 실시, 반기 1회 정기 재검토 의무화	IT인프라팀장 박찬기 정보보호팀장 김채윤

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
개인정보처리시 스템 접근 권한	퇴직한 외주 인력 계정 1건 잔류, 개인정보취급자 명단 미등재 계정 존재 - 활성상태 유지	외주 인력 계약 종료 당일 계정 말소 체크리스트 시스템화, 퇴직 후 말소 절차 활성화, 월 1회 전체 계정·권한 대조 점검 보고서 작성	IT인프라팀장 박찬기 인사팀장 이선호
인사이동 계정 말소	외주 인력 수동 말소 구조로 누락 발생 -	외주 인력 계약 종료 당일 계정 말소 체크리스트 시스템화,	IT인프라팀장 박찬기

구분	현황·문제점	개선 방안	담당자
	퇴사 후 6개월 경과 계정 잔류 사례 1건 확인	월 1회 전체 계정·권한 대조 점검 보고서 작성	인사팀장 이선호

2.3 접속기록 보관 및 점검

점검 결과 등급: A

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
정기 검토 미흡	SIEM 실시간 이상탐지 운영 중이나 임계치 기준 내부 규정 미명시, 담당자 경험 기반 운영. 최근 3개월 이상탐지 이벤트 로그 존재하나 월 1회 검토 보고서 미작성	SIEM 탐지 룰셋·임계치 기준 내부 보안운영지침에 문서화, 월 1회 접속기록 검토 보고서 작성 및 CPO 보고 의무화, 대체 담당자 지정으로 단일 실패점 제거	정보보호팀장 김채윤

2.4 비밀번호 관리

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
레거시 시스템 비밀번호	레거시 모니터링 콘솔 비밀번호 유효기간 미설정, 최장 14개월 미변경 계정 2건 확인. 일부 시스템 임시 비밀번호 강제 변경 미적용	레거시 콘솔 비밀번호 유효기간 90일 설정 즉시 적용, 미변경 계정 2건 임시 비밀번호 발급 후 강제 변경 처리, 반기 1회 전 시스템 비밀번호 정책 적용 여부 검증 이력 보관	IT인프라팀장 박찬기

2.5 접속 보안 및 네트워크

점검 결과 등급: B

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
SSL 검사 미적용	URL 필터링·비인가 프로그램 차단 정책 미설정 및 SSL 검사 미적용으로 HTTPS 통신의의 개인 클라우드파일 업로드 탐지·차단 불가 - 테스트 시 차단 없이 업로드 성공 확인	주요 개인 클라우드 도메인 웹 필터 차단 목록 즉시 추가 후 URL 필터링·SSL 검사 솔루션 도입 예산 및 일정 계획 수립, DLP 도입 중장기 계획 포함	IT인프라팀장 박찬기

2.6 단말기 보안

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
SFTP 서버 OS 패치 지연	주요 서버(API·결제 DB) 월 1회 정기 패치 양호. SFTP 서버 마지막 OS 패치 5개월 경과, CVE 취약점 3건 미패치 — 담당자 재부팅 우려로 지연	SFTP 서버 CVE 취약점 3건 즉시 패치 적용	IT인프라팀장 박찬기
NAS 공유 폴더 노출	NAS '결제정산_2025' 폴더에 전체 임직원 읽기 권한 부여, 결제이력 파일 12건 평문 저장. 접근 제한·암호화·로깅 미조치	폴더 접근 권한 담당팀장 승인 계정으로 즉시 축소, 평문 파일 12건 AES-256 암호화 또는 별도 보안 서버 이관, 접근 감사로그 활성화 및 월 1회 이력 점검 의무화	IT인프라팀장 박찬기 정보보호팀장 김채윤
단말 패치 예외 관리 미흡	WSUS 연동 자동 패치 배포 운영 중이나, 패치 미적용	승인 만료 예외 단말 2건에 대해 즉시 재승인 또는 패치 적용 조치, 예외 단말 운영 시 네트워크 격리	IT인프라팀장 박찬기

구분	현황·문제점	개선 방안	담당자
	단말 2건 확인, 예외 처리 문서는 존재하나 승인이 완료된 상태로 운영 중이며 네트워크 격리 등 대체 통제 미적용 상태	등 대체 통제 의무화 및 예외 승인 완료 전 알림 체계 수립	

2.7 개인정보 암호화 및 출력통제

점검 결과 등급: B

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
출력물 관리 미흡	결제 이력 관련 출력물 관리대장 미기재 항목 확인, 출력 DLP 미적용 및 보안 출력 솔루션 미도입, 점검 당일 결제 승인 내역 출력물 3건이 프린터 트레이에 30분 이상 방치된 것을 현장에서 직접 확인	출력물 관리대장 전수 점검 및 누락 건 즉시 소급 기재, 프린터 주변 출력물 방치 금지 지침 재공지 — 보안 출력 솔루션 및 출력 DLP 도입 예산·일정 계획 수립	정보보호팀장 김채윤

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
전송 구간 HTTP 미암호화	주요 구간 mTLS+TLS 1.3·PGP 암호화 적용 양호. 단, 관리자 PC↔결제 DB 콘솔 접속 구간 일부 HTTP 비암호화 통신 확인	관리자 PC↔콘솔 구간 HTTPS 또는 TLS 1.2 이상 암호화 통신 즉시 전환, 전 시스템 통신 구간 암호화 현황 전수 점검 및 미적용 구간 정비	IT인프라팀장 박찬기

2.8 개인정보 생명주기

점검 결과 등급: D

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
재위탁 서면 승인 미비	마일리지 정산 배치 업무를 (주)한길 회계법인에 재위탁하면서 (주)하랑항공 서면 승인 없이 구두로만 진행, 재위탁 계약서 미체결	(주)하랑항공 서면 승인 소급 취득, (주)한길 회계법인과 재위탁 계약서 즉시 체결 (목적 외 처리 금지·손해배상·교육 의무 조항 포함), 내부관리계획서 내 재위탁 감독 절차 추가 및 연 1회 재수탁사 보안 점검 일정 수립	법무팀장 김태민 정보보호팀장 김채윤
보유기간 초과 미파기	결제이력 자동 파기 배치(90일 기준)가 스키마 변경으로 3개월간 오류 상태 방치 - 보유기간 초과 데이터 2,341건 미파기	파기 배치 스크립트 오류 즉시 수정 및 완전 테스트, 초과 2,341건 수동 파기 실행, 배치 실패 시 담당자 알림(이메일·SIEM 연동) 체계 구축, 월 1회 파기 현황 CPO 보고	개발팀장 박찬준
파기 결과 보고 누락	개인정보 파기 결과 (주)하랑항공 보고 절차 미수립. CPO 내부 보고도 분기 1회에 그침	파기 배치 완료 후 자동 이메일 보고 연동 구현 (주)하랑항공 담당자 수신), 파기 결과 보고 월 1회 이상으로 주기 강화 및 담당자 SLA 수립	개인정보보호팀장 김유연

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
반출입 관리 대장	개인정보 파일 반출입 관리대장 기재율 부분 누락 미승인 이메일 발송 사례 1건 확인	반출입 관리대장 100% 기재 의무화 및 미기재자 경고 프로세스 수립, 이메일 DLP 정책 강화 - 첨부파일 발송 시 개인정보 포함 여부 승인 절차 의무화	정보보호팀장 김채윤
종이 문서 파기 미흡	종이 문서 세절 파기 절차 일부 시행 종이나 파기 대장 기재 현황 미흡	종이 문서 파기 시 파기 대장 100% 기재 재교육 실시, 파기 예정 문서 분리 수납함 운영 및 주 1회 파쇄 일정 의무화	정보보호팀장 김채윤 총무팀 박하민

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
분리 보관 및 접근통제	전자금융거래법·신용 정보법 기준 분리 DB 운영 확인 단, (주)하랑항공 전용 스키마 분리 운영 중이나 접근통제 레이블 미비	분리 보관 DB 접근통제 레이블 추가 적용, 보존 기간 만료 자동 파기 배치 정상 작동 여부 점검 및 알림 연동	개인정보보호팀장 김유연

3. 이행 점검 로드맵

개선방안 이행은 아래 3단계 로드맵에 따라 추진하며, 각 단계 완료 시 (주)하랑항공 개인정보보호팀에 이행 결과를 보고한다.

각 단계 완료 후 이행 결과보고서(증적자료 포함)를 (주)하랑항공 개인정보보호팀장에게 제출한다.

이행 중 기술적 제약, 예산 문제 등으로 일정 변경이 필요한 경우 사전 협의 후 서면 승인을 득하여야 한다.

단계	기간	주요 이행 항목	이행 결과 보고 기한
긴급 조치	~2026.04.30	보안서약서 즉시 징구·권한 재검토 / 침해사고 대응절차·비상연락망 (주)하랑항공 포함) 수립 / 레거시 콘솔 비밀번호 정책 적용 / NAS 폴더 접근통제·암호화 / 결제이력 파기 배치 오류 수정 및 2,341건 파기 / (주)한길 회계법인 재위탁 서면승인 취득·계약서 체결 / SFTP 서버 CVE 패치	2026년 05월 12일
단기 조치	~2026.07.12	API 개발팀 운영 DB 권한 분리 / 사용자 권한 적절성 검토 실시 / 외주 계정 말소 프로세스 자동화 / SIEM 임계치 기준 문서화·월간 검토 보고서 / 반출입 관리대장 100% 기재 / SSL 검사 도입 검토·웹필터 임시 통제 / 파기 결과 보고 체계 수립 / SFTP 서버 패치 및 미적용 단말 처리	2026년 07월 12일
중기 조치	~2026.10.12	관리자 PC↔콘솔 구간 TLS 암호화 적용 / 보안 출력 솔루션 도입 / DLP 솔루션 도입 계획 수립 / 분리 보관 DB 접근통제 레이블 적용 / 자동 파기 배치 개선 및 알림 연동	2026년 10월 12일
재점검	2026.11월 중	(주)하랑항공 현장 재점검 실시 - 전 항목 이행 완료 여부 및 잔존 취약점 재확인	2026년 11월 중

4. 결론 및 향후 조치 계획

(주)해랑금융은 이번 점검에서 확인된 총 21건(취약 10건, 부분양호 11건)의 취약 사항에 대한 구체적인 개선방안을 수립하여 이행할 책임이 있다. 특히 결제이력 자동 파기 배치 오류가 3개월간 방치된 점, 그리고 (주)하랑항공 위탁 데이터에 대한 파기 결과 보고 절차가 전혀 수립되어 있지 않은 점은위반 사항으로, 금번 개선방안 이행에 있어 최우선 순위로 처리하여야 한다.

위탁사인 (주)하랑항공은 수탁사의 이행 상황을 아래 일정에 따라 모니터링하고, 이행이 지연되거나 불충분한 경우 계약 조항에 따라 필요한 조치를 취할 수 있다.

4.1 향후 조치 일정

구분	일정	내용
조치계획서 제출	2026년 04월 29일까지	(주)해랑금융 → (주)하랑항공 제출 (담당자 서명 필수)
긴급 항목 이행 보고	2026년 05월 12일까지	보안서약서 징구·DB 접근권한 축소·NAS 암호화 이행 결과 보고
단기 항목 이행 보고	2026년 07월 12일까지	출력물 DLP·반출입관리·파기배치 등 이행 결과 보고
중기 항목 이행 보고	2026년 10월 12일까지	재위탁계약·SSL 검사·위탁사SLA 이행 결과 보고
현장 재점검	2026년 11월 중	(주)하랑항공 주관 현장 재점검 실시 (전 항목 확인)